



ISACA®

Session 3 Activity Book

MODULE 3

Activity 3.1: Roles and Responsibilities

Match the task with the correct role.

Risk Owner

Ensures selected controls are monitored, maintained and reported on

Control Owner

Empowered to make decisions on behalf of the enterprise with respect to risk

Risk Practitioner

Communicates with risk owners to ensure awareness of risk responses already implemented and responses that are pending implementation



Activity 3.2: Match the Risk Response

The marketing department of a software company employs 12 graphic designers and videographers to develop assets and content.

They require professional software not normally used by the average employee. The IT and Finance Department are both reluctant to allow this for multiple reasons including cost, security and complexity. The current policy is vague.

Currently, these employees are required to share logins to use the software product (Adobe Creative Cloud). Recently, several employees are unable to coordinate access. To get around this, some bought their own subscription and requested reimbursement.

The company is currently unaware of how many users now have their own credentials and are accessing company data with those credentials. What risks can you identify in this scenario? What treatment would you apply? Are there conditions required to ensure compliance?



Activity 3.2 Worksheet

You are a risk practitioner for this organization and the risk manager has asked you for your input on the situation. For this exercise, identify potential risk scenarios that you might suggest and responses (accept, mitigate, share, transfer) for those scenarios.

Risk Scenario	Risk Response
	Acceptance
	Mitigation
	Sharing
	Avoidance

Activity 3.3: Exceptions and Changes Scenario

A managed service provider has identified multiple modifications that need to be made to its customer relationship management system. This system has been designed and managed internally by the organization.

Change control is new to the enterprise, and you are a consultant engaged to assist in determining how to process changes to the live environment.

Using the given scenario, discuss some exceptions and changes needed on the provided worksheet. Based on the information you have, should the change/exception be allowed? Do you need more information? Discuss your answers as a group.



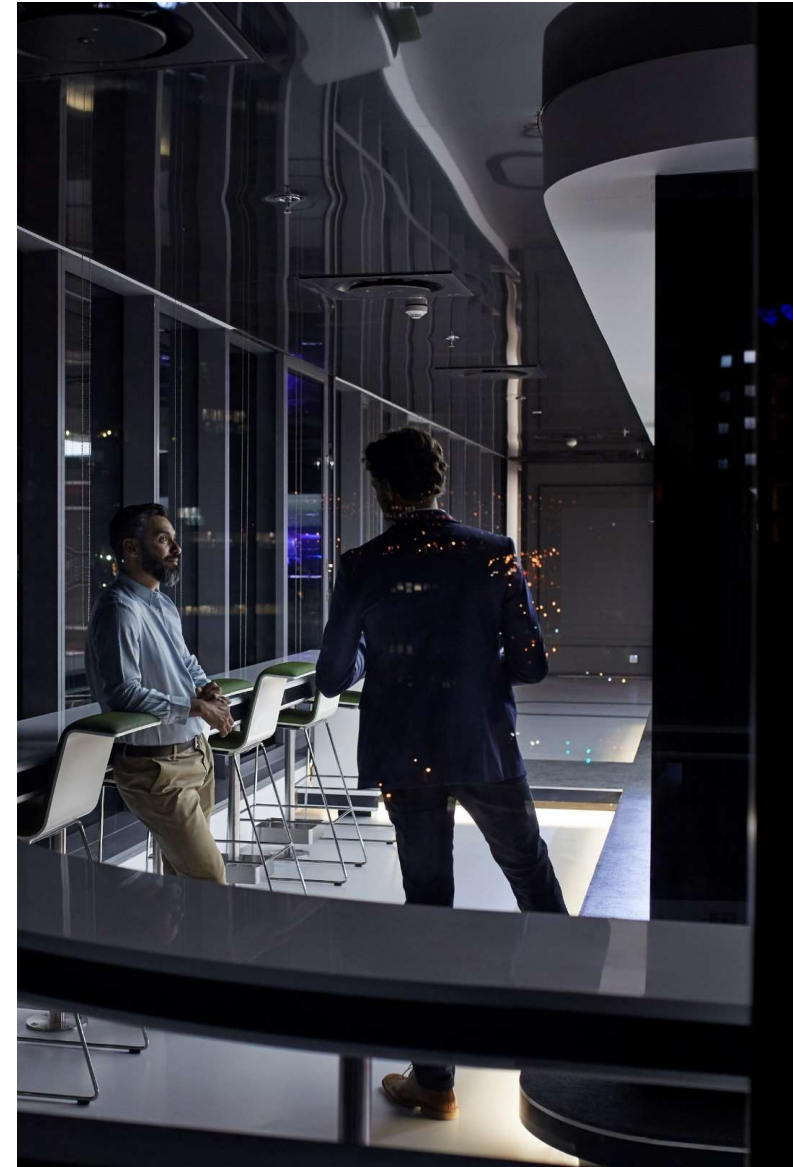
Activity 3.4: Third-Party Risk

As a group, discuss your experience in reviewing contracts and SLAs. What are some frequent areas of concern? How do you communicate these concerns with stakeholders? What strategies do you use to manage these concerns?



Activity 3.5:

Using the provided worksheet, consider some common controls of each type. Then discuss as a group how these controls are ideally used with various types of risk.



Activity 3.5 Worksheet

Administrative	Technical	Physical

Activity 3.6:

Describe how capability maturity models can be used with other control standards and frameworks. Are there some that align particularly well? Are there any drawbacks of using a capability maturity model? Discuss as a group.



Activity 3.7:

A software company has secured a large development contract with a key client to create a custom module for their business.

Due to a lack of current resource capacity and software testing skills, the software company is hiring several contractors to complete the work and outsourcing their testing activities to an outside provider.

First identify some risk examples. Then, consider key steps to address the risk. Discuss your answers as a group.



Activity 3.8: Control Implementation

Match the scenario with the best suited implementation style.

A bank is launching a new data center and wants to keep the current data center live to facilitate migrations before retiring it.

A food distributor wants to roll out GPS tracking systems on its fleet and chooses a pilot followed by multiple monthly deployments.

A recording studio is using spreadsheets to track customer information and chooses a completely new CRM system.

Abrupt

Parallel

Phased



Activity 3.9:

An online retailer is replacing its data loss prevention (DLP) solution because of multiple new privacy and cybersecurity regulations, findings from internal audit, and a growing concern over the potential loss of any personal information they collect.

Given the scenario, which tests would be most appropriate to perform? Which good practices can be applied and improve or optimize testing? Discuss your answers as a group.



Activity 3.10: Risk Response Process

Apply your experience in the risk response process.

How do monitoring and reporting drive choices in your enterprise? Are people really reviewing what they should be? How can you encourage more proactive behavior?

Discuss your answers as a group.



Activity 3.11: Sourcing Risk Data

Using the provided worksheet, outline some beneficial ways and situations to use each data type. Then, discuss your answers as a group. Be prepared to explain and justify your opinions.



Activity 3.11 Worksheet

Prior Risk Assessments	Logs
Audit/Incident Reports	User Feedback

Activity 3.12: Control Assessment Types

Match the control assessment description with the corresponding control assessment type on the right.

Methodical security review to ensure no predictable and unaddressed attack vectors

Targeted attempt to break into an environment

Independent and objective review of the effectiveness and appropriateness of the control environment

Penetration Test

Vulnerability Assessment

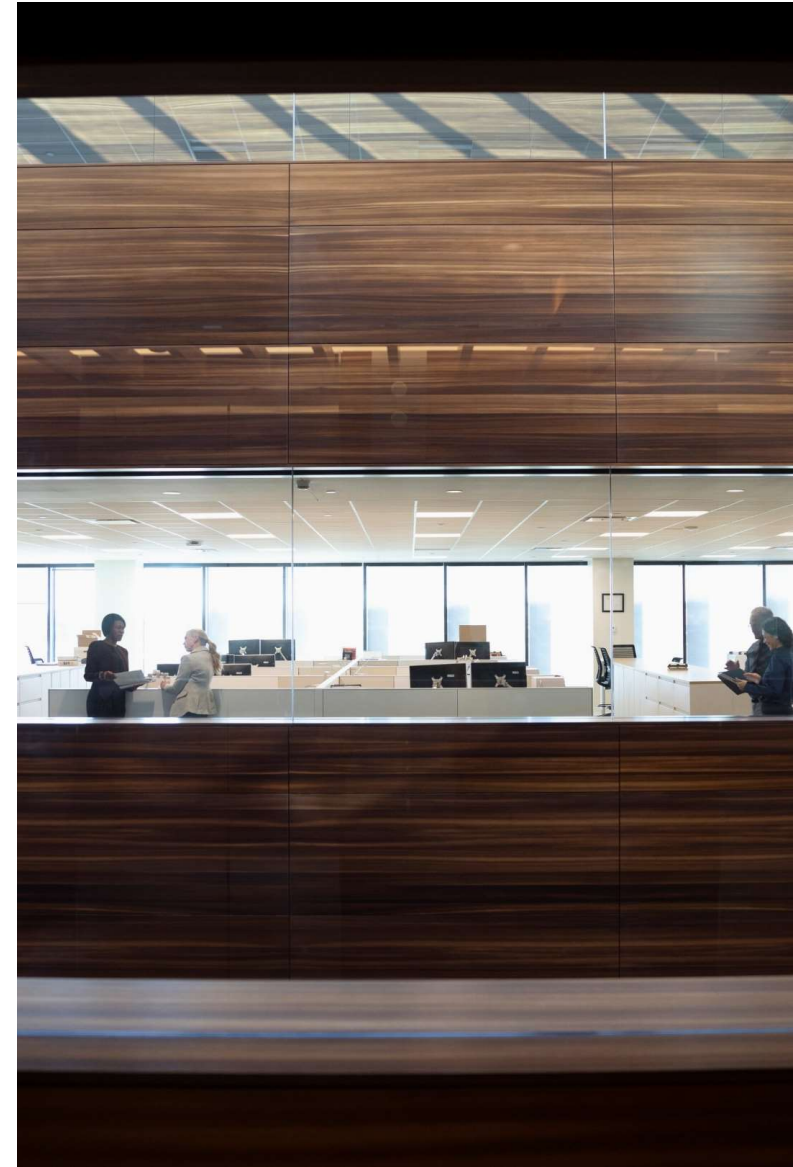
IS Audit



Activity 3.13:

Executives at a large financial firm are frequently concerned with potential cyberattacks and possible fraudulent activity. They are mostly concerned with the overall health of security at the organization. With many different possible threats, the risk management team wants to triage notable issues without being distracted by noncritical issues.

Given the scenario, which type of reporting is the best ongoing solution? Discuss as a group and be prepared to justify your answers.



Activity 3.14:

When using KPIs, it is critical to establish a process to define, monitor and analyze the relevant metrics to enterprise risk. On the provided worksheet, outline some key actions to complete in each step of the process.

Then, discuss as a group how you or your enterprise effectively performs these key actions.



Activity 3.14 Worksheet

Define	Monitor	Analyze

Activity 3.15:

A regional delivery enterprise wants to better track its fleet of vehicles, drivers and inventory for better maintenance and safety.

Identify metrics you would suggest in each category on the provided worksheet to help this enterprise further optimize its tracking.



Activity 3.15 Worksheet

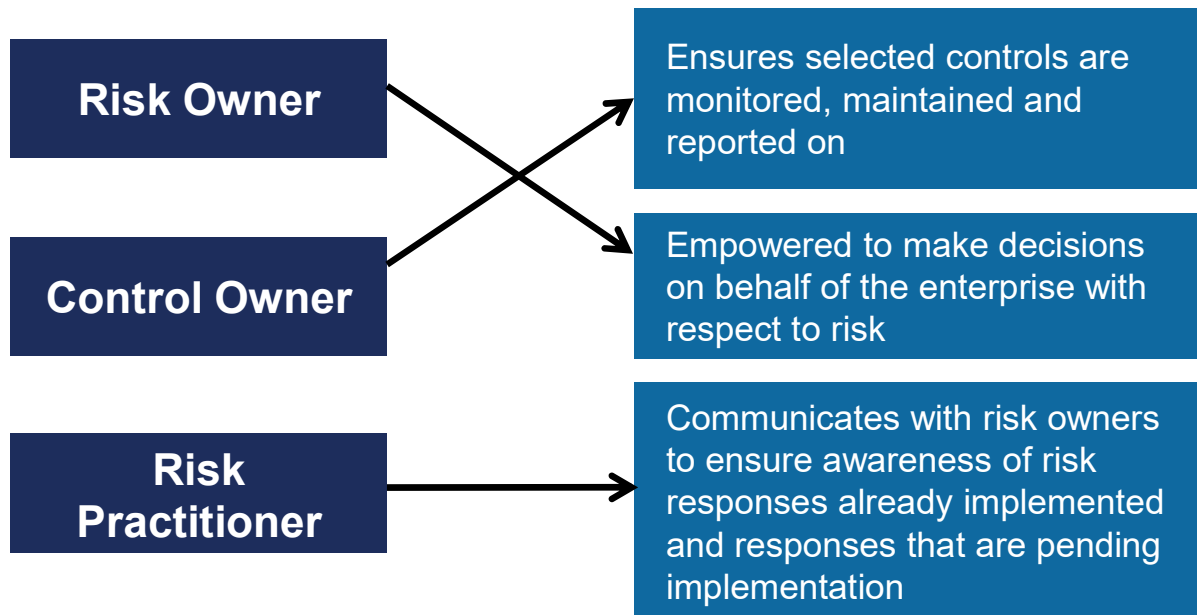
Sensitivity	Timing
Frequency	Corrective Action



Answers

Activity 3.1: Roles and Responsibilities

Match the task with the correct role.



Activity 3.8: Control Implementation

Match the scenario with the best suited implementation style.

A bank is launching a new data center and wants to keep the current data center live to facilitate migrations before retiring it.

A food distributor wants to roll out GPS tracking systems on its fleet and chooses a pilot followed by multiple monthly deployments.

A recording studio is using spreadsheets to track customer information and chooses a completely new CRM system.

Abrupt

Parallel

Phased



Activity 3.12: Control Assessment Types

Match the control assessment description with the corresponding control assessment type on the right.

